ביקורת תלויות וסודות (אנגלית)

מסמך	ביקורת תלויות וסודות (אנגלית)
נתיב המקור	docs/security/DEPENDENCY_AND_SECRETS_AUDIT.md
גרסת המקור	origin/main @ b6eb212ec
הוכן לחבילה	2026-10-24
מצב	הנוסח המקורי נשמר ללא שינוי; עיצוב בלבד. טיוטה לבדיקת עורך דין, אינו ייעוץ משפטי.

ביקורת אבטחה של תלויות וניהול סודות במוצר (אנגלית); המקבילה העברית בקובץ 02.

Dependency, licence and secrets audit (T005)

Date: 2026-09-16 (first audit at 0.1.21) · re-run 2026-09-22 at 0.1.81 (§2, §6) · Scope: the add-on repository (backend, integration, frontend, image) · Method: inventory from the lock files, `pip-audit` and `npm audit` runs on the workstation, `git grep` for credentials and lab addresses, review of every path the add-on writes to. Re-run before each pilot release (`python -m pip_audit -r smplwise_vms/backend/requirements.txt`, `npm audit` in `frontend/`, the tracked-tree grep in §3).

1. Runtime inventory and licences

Component	Version	Licence	Use	Notes
Home Assistant base image `amd64-base-python:3.12-alpine3.22`	as pinned in Dockerfile	Apache-2.0 (HA add-on base)	image base	official HA base
fastapi	0.141.1	MIT	HTTP API	
uvicorn[standard]	0.53.0	BSD-3	ASGI server	`standard` extras: httptools (MIT), uvloop (MIT/Apache), websockets, watchfiles (MIT)
pydantic	2.13.5	MIT	validation	
httpx	0.27.2	BSD-3	NVR / go2rtc / HA calls	
websockets	≥13,<16	BSD-3	HA WebSocket, go2rtc relay	
python-multipart	0.0.32	Apache-2.0	uploads	
pillow	12.3.0	MIT-CMU (HPND)	plan rendering	
numpy	≥2,<3	BSD-3	plan stylization / room detection	
cryptography	≥45,<51 (50.0.1 on the workstation)	Apache-2.0 OR BSD-3	Ed25519 evidence-bundle signing (0.1.67); Web Push VAPID (ES256) and RFC 8291 `aes128gcm` encryption (CR-008 P3 - chosen over adding pywebpush)	added after the first audit

Component	Version	Licence	Use	Notes
ezdxf	≥1.3,<2 (1.4.4 on the workstation)	MIT	DXF plan import (0.1.43)	added after the first audit; pure Python
tzdata	≥2024.1	Apache-2.0	time zones	
poppler-utils (Alpine)	distro	GPL-2.0 / GPL-3.0	`pdftoppm` **as a subprocess**	not linked into our code; invoked per page with a timeout
ffmpeg (Alpine)	distro	LGPL-2.1+ / GPL-2.0+ (Alpine build enables GPL parts)	frame grabs, export remux **as a subprocess**	not linked; command lines redacted in logs
jpeg, zlib, libpng (Alpine)	distro	IJG / zlib / libpng	Pillow codecs	permissive
lit	^3.3.3	BSD-3	UI components	only runtime frontend dependency
vite, typescript, @playwright/test, @types/node	dev only	MIT / Apache-2.0 / Apache-2.0 / MIT	build and tests	not shipped
Legacy add-on `legacy/hikvision_nvr_v1.5.27`	—	owner's own code, no licence file	read-only reference	never copied into the product; reuse only as documented in `docs/legacy/REUSE_MATRIX.md`
Design assets (`docs/design/mockups-v1.3`, boards)	—	owner-supplied	reference	full PNG set kept privately

No vendored third-party source is copied into the product. The stylization, room detection and backup code are original. The bridge integration (`custom_components/smplwise_bridge`) depends only on Home Assistant core APIs.

2. Vulnerability scan

Scan	Result (2026-09-16, 0.1.21)	Result (2026-09-22, 0.1.81)
`pip-audit -r smplwise_vms/backend/requirements.txt`	No known vulnerabilities found	No known vulnerabilities found (11 requirements incl. cryptography, ezdxf)
`npm audit` (frontend, runtime + dev)	0 vulnerabilities (info/low/moderate/high/critical all 0)	0 vulnerabilities; 7 prod / 70 dev packages; runtime dependency still `lit` only
tracked-tree grep (credentials, tokens, lab addresses, serials, MACs; `legacy/` scanned separately)	no hits apart from a fake fixture string	0 hits; `legacy/` 0 hits

Both scans go into the release checklist (T036); a finding of severity high or above blocks a release until the dependency is updated or the exposure is documented as not reachable.

3. Secrets

- Secrets never live in the repository or the database, except where an approved change request names the exception, its protection and its limits. NVR credentials, go2rtc credentials and (in development) the HA token come from the add-on options / `secrets/lab.env`, which is git-ignored together with `private-evidence/` and `data/`. The bridge shared secret is stored in the settings table of the add-on database and excluded from backups (`SETTINGS_KEEP` in `services/backup.py`).
- Approved exception (CR-022, owner decision 2026-10-04; backend implemented on `pilot/nn4-backend`, ships with the CR-022 release): the NVR connection password moves from the add-on options into `recorder_connections.password_enc`, encrypted with AES-256-GCM under its own key file `<data>/keys/connections.key`; neither the table nor the key enters an Arx backup or bundle, and the password is never returned by an API or written to a log or the audit trail. It protects against a leaked database file or Arx backup, not against a reader of the whole data folder. Scope, threat model and tests: `docs/changes/CR-022-NVR-CONNECTION-IN-ARX.md` §3. Until that release the add-on options remain the source.
- Project backups, encrypted sensitive section (BACKUP-HASH-ENC, owner decision 2026-10-17; `services/backup_sensitive.py`): the Arx-only accounts' password hashes (`auth_local_credentials.password_hash`, scrypt PHC) and the media HMAC keys (`multimedia.item_secret`, `multimedia.cast.secret`) never appear in an archive's data files. With a backup password typed at export time they are sealed into `secure/sensitive.bin`: AES-256-GCM (`cryptography`), key = scrypt(password, 16-byte random salt, N=2^17, r=8, p=1); the header (salt, nonce, KDF settings, counts) sits in the manifest and is authenticated as associated data together with the archive's `created_at` / `schema_version` / `format`. Without a password the section is omitted (never plaintext); automatic (daily / pre-upgrade) backups always omit it. Restore: the password is required, or the operator explicitly chooses "restore without the passwords" - then an account keeps the current hash of the same user id on this installation, and otherwise needs an administrator's reset link. A wrong password and a changed / truncated section are refused before anything is written (the GCM tag is the only, constant-time, password check; no verifier is stored). Downgrade guards: a ciphertext member without its header, or a header saying "omitted" next to one, is refused even with the skip choice; plaintext hashes / keys injected into an archive that has a header are ignored; KDF settings above what the build writes are refused before any derivation (one derivation at a time, ciphertext size-capped). Archives from before the rule (no header) still import their plaintext hashes, with a warning in the answer and the log. The password and the derived key are never logged, audited, stored or returned. Residual risk: an attacker with the archive can run an offline guess against the backup password at the scrypt cost (minimum length = setting `backup.password_min`, default 12, an administrator may set 8-64; values outside are refused, a stored value is clamped, so 8 is a hard floor; the setting is never exported or restored); the rest of the archive stays unsigned and unencrypted as before. Tests: `tests/test_backup_sensitive.py`.
- Repository scan (`git grep` for `password=`, `token=`, lab address patterns; the pre-commit scan used by the segment loop refuses commits containing lab addresses or device identifiers): no hits apart from an obviously fake fixture string in `tests/test_media.py`.
- Logs: go2rtc URLs are redacted (`services/go2rtc.redact_url`), ffmpeg error output is redacted before it is stored (`services/thumbnails._redact`), health details name error classes rather than addresses, and

the developer launcher never echoes option values. Uvicorn's access log shows the client address, which inside the add-on is the Supervisor proxy.
- The UI never receives credentials: the browser talks only to the add-on, which relays go2rtc signalling and NVR pictures itself (ADR-005 / ADR-011).

4. Dangerous write paths (reviewed)

Path	Guard
Plan uploads → `/data/plans`	content sniffing (PDF/PNG/JPG only, SVG rejected), 40 MB / 20 pages, derived images written next to the original, originals immutable
Backups → `/data/backups`	zip written to a temp name then renamed; restore extracts only `files/…` members under the data directory and refuses `..` segments; rows and files in one transaction
Exports → `/data/exports`	job directory per export, temp + rename, size accounted in the health report
Event pictures → `/data/thumbs`	one worker, temp + rename, negative cache, ffmpeg with timeout
Bridge install → Home Assistant `custom_components/smplwise_bridge`	only when the `homeassistant_config` mapping is granted, only that directory, version-marked, re-copy on version change; documented in DOCS.md
go2rtc streams	only names with the `smplwise_` prefix are created, updated or deleted; foreign streams are listed but never touched
NVR	read-only ISAPI calls; no configuration writes, no reboots (AGENTS.md rule; `nvr.config.write` is a sensitive permission that no role grants)
Add-on infrastructure API (Supervisor), **approved exception** (CR-021 owner decision D1; S3 backend on `pilot/CR021-s3`, ships with the S3 release)	the manifest requests `hassio_role: manager`, which in principle allows backups, other add-ons, host and store-repository calls. Arx confines itself to ONE egress door, `services/self_update.py`: an exact (method, path) allow-list (`/addons/self/info`, `/store/reload`, `/store/addons/{slug}/update`, `/jobs/info`, `/core/info`, `/core/check`, `/core/restart`, `/addons/self/options`, `/addons/self/restart`), exact body keys, a slug pattern for the one templated path, no redirects, no upstream text echoed or stored; a CI test fails when an infrastructure write path is spelled anywhere else. Only `system.update` holders (system administrators, never delegable) trigger the two actions; permission and audit before the body is read; one active run at a time; the update can only go to the store's latest version (never an attacker-chosen one); the platform restart runs only after a passed configuration check. Residual risk (accepted by D1): a compromised Arx process could use the role directly - see `docs/changes/CR-021-SELF-UPDATE.md` sections 3.2, 11 and 13. Release gate: branch protection + required review on the store repository (owner answer 11)

5. Findings and follow-ups

1. **poppler / ffmpeg licences** — GPL components are used as separate processes, which keeps the add-on's own code under its own licence; keep it that way (no linking, no bundling of modified binaries).

2. **Legacy code licence** — the legacy add-on has no licence file; it stays a read-only reference under `legacy/` and is never redistributed with the product.
3. **Scan cadence** — add both audit commands to the pilot release checklist (T036) and to the technical review record of each release.
4. **Access log addresses** — acceptable inside Home Assistant (proxy address); for a standalone deployment the access log should be turned down to WARNING (already possible through the `log_level` option).

No finding blocks fixture distribution or the pilot build.

6. Re-scan log

Date	Version	pip-audit	npm audit	tree grep	New since the previous scan
2026-09-16	0.1.21	clean	0	fake fixture only	—
2026-09-22	0.1.81	clean	0	0	`cryptography` (signing), `ezdxf` (DXF import) added to the inventory with their licences; dev tooling moved to Playwright 1.63 / Vite 6.4 / TypeScript 5.9; the secret scan now also refuses serial numbers and MAC addresses (the segment loop's pre-commit gate has done so since 0.1.6x). The pre-commit gate ran with 0 hits on every release commit of 2026-09-22 (0.1.76–0.1.81).

Still open from T069 that this re-scan does not cover: oversized media pushed through go2rtc (needs the relay), the go2rtc API/RTSP exposure review on the owner's host (owner), and Ingress-session token replay, which is Home Assistant's session layer and is recorded as an explicit exclusion (the add-on never sees or stores that token; the bridge's own HMAC replay window is tested in `tests/test_security.py`).